

Malicious-HDG

Heterogeneous dynamic graph framework for malicious-domain / DGA detection (ISRO project). Status, audit, limitations and a scope that can actually be completed. Prepared 30 September 2026.

1. Bottom line

- **The status log you attached is honest in spirit but overstated in two places.** Its 'validated GNN pipeline' rests on a synthetic dataset that is almost certainly trivially separable, and it does not mention that the real-data numbers in your notes (F1 0.946) are not DGA results.
- **The biggest factual problem:** the Zenodo malware.json file is not DGArchive. Its malware domains come from ThreatFox, URLhaus, The Firebog, MISP and similar feeds, and malware_type is a family name or 'unknown'. The README line 'Malicious: DGArchive' and the 'wordlist-DGA' task framing are unsupported by the data actually parsed.
- **What can honestly be delivered:** a rigorous infrastructure-graph detector for *malware domains* on the public Zenodo corpus (with TLS certificate nodes it already contains), evaluated with time-aware and group splits, FPR-anchored metrics and measured latency. A true wordlist-DGA study needs DGArchive access (free, vetted) plus your own infrastructure enrichment.
- **What should be cut or reframed as future work:** per-event streaming at 60-300 s TTL, continual learning, and full GNNGuard defence. None has a data source or an off-the-shelf implementation that fits this project.

2. Is the attached status log correct?

Claim in the log	Verdict	Evidence / fix
DGArchive needs vetting; not bypassed	Correct	DGArchive's own page: access by email, institutional address preferred, credentials after a brief vetting.
SHetGCN and GNNGuard exist as named in the proposal	Correct	SHetGCN is from DeepDom (Sun et al., Computers & Security, 2020): meta-path-guided random walks plus attention aggregation. GNNGuard: Zhang & Zitnik, NeurIPS 2020.
Current model is GraphSAGE, not SHetGCN; no GRU in main path	Correct	Matches models/encoder.py and full_model.py. temporal.py (GRU) is present but unused.
CHMOR has no infrastructure, so it is only a lexical baseline	Correct	Columns are label/family/domain only. Numbers (674,837 domains, 25 families, F1 0.960) not re-verified by me.
Synthetic GNN results (F1 0.996) show the pipeline works	Overstated	They show the code runs. 00_generate_demo_dataset.py names malicious domains xqz{i}.com and benign normal{i}.com, so domain <i>length</i> alone nearly separates the classes; recall = 1.0 fits that. Never quote these as evidence of model quality, even internally.
Two clean 'validated tracks'	Incomplete	Your other notes describe a Zenodo-based graph (23,782 IPs, 970 registrars, F1 0.946, 28 snapshots). The log describes a synthetic graph (254 IPs, 3 registrars, 26 snapshots). Decide which data state the repo represents and label results accordingly.
'Malicious: DGArchive' (README)	Incorrect	Zenodo malware.json sources are ThreatFox, URLhaus, Firebog, MISP (dataset paper, Data in Brief 2025). Fix the README and the task description.
CHMOR vs OpenINTEL: DGA coverage ~2%	Plausible, and an important finding	Most algorithmically generated domains are never registered, so no DNS infrastructure exists to observe. See section 4.
Minor slips	Fix	'30,000 malicious' typo (it is 15,000 + 15,000); 26 vs 28 snapshots; rolling-origin means on synthetic data (0.996 +/- 0.002) should be dropped from any table.

The 'pending work' log is directionally right (data first, then real graph, temporal splits, baselines, then advanced components) but lists 27 items as if all were feasible. Section 5 says which are.

Scope note: I reviewed the repository files and status logs in this conversation. No updated models file was visible in the latest attachments, so my model comments rely on the models/ files shared earlier.

3. Audit of the repository (what would break a reviewer's trust)

#	Finding	Why it matters	Fix
1	Label is confounded with time: benign = one static Umbrella list, malicious = feed over time; later snapshots are all-malicious (your own note 14).	Random split and rolling-origin F1 partly measure 'which week'. All-malicious windows make F1 = recall and AUC undefined.	Sample benign across the same time range; report class counts per window; only score windows with both classes.
2	Contradiction: note 14 says snapshots 12+ are all malicious, yet 14_temporal_holdout.py reports AUC 0.938 on snapshots 26-27 (impossible with one class). Variable largest_two actually picks the two highest IDs.	One of the two statements is wrong.	Run labels.groupby(snapshot).y.agg(['mean','count']) and settle it.
3	'Dead domain' shortcut: unregistered/NXDOMAIN domains have no IP/NS/registrar edges; nxdomain is a direct feature.	Model may learn 'resolves vs not', not 'DGA vs benign'.	Single-feature baselines; report F1 on domains that resolve and have a registrar.
4	No lexical baseline on the same 30k domains; domain features are only length, TLD flags, nxdomain, has_tls.	If char n-gram TF-IDF beats 0.946 the graph adds nothing.	Run 02_chrmor_lexical_baseline logic on the same split; then graph + lexical.
5	fanin features and z-score statistics computed on all 30k domains, including test and future.	Transductive leakage, worst in temporal experiments.	Compute from training window only.
6	Split fixed at seed 42 in every 'seed' run; seed 123 chosen as best on test.	'0.943 +/- 0.002' is init variance only; best-seed reporting is test selection.	Vary split seeds; report mean +/- std.
7	Temporal scripts use lr 5e-4 and longer patience than main run.	If tuned after seeing test windows, that is test tuning.	Fix hyperparameters on validation before any temporal test.
8	Ablation is one seed, patience 10; 0.919 vs 0.920 is noise. McNemar 'chi2 = 86' with p = 3e-150 is inconsistent.	Likely exact test where statistic = min(b,c).	Repeat ablation over 5 seeds; label the test correctly.
9	Hygiene: .gitignore last two lines merged (*.ptresults_paper_ready.zip); requirements.txt lacks xgboost/statsmodels, unpinned; nodes_edges_count.py subtracts 1 from read_csv length; duplicate 01_02_ script numbers; train loops copy-pasted across 7 scripts.	Reproducibility and silent drift.	Fix, pin versions, factor common.py.

4. What data actually exists (verified against public sources)

Source	What it really contains	Use for this project
Zenodo: DNS/IP/WHOIS-RD AP/TLS/GeoIP dataset (DOI 10.5281/zenodo.13330073; Data in Brief 2025)	368,956 Umbrella benign domains; 461,338 CESNET benign; 164,425 phishing; 100,809 malware domains (ThreatFox, URLhaus, Firebog, MISP...). DNS, IP, RDAP, TLS handshakes and certificates, GeoIP. Collected from a server at Brno University of Technology.	Best available infrastructure source. Real multi-modal enrichment already done. Certificate data lets you add the TLS-certificate node the proposal asks for. Malware label, not DGA label.
DGArchive (Fraunhofer FKIE)	Domains generated by reverse-engineered DGAs (over 100 DGAs in recent papers). Free, but access is by email vetting. Provides domains, DGA family and generation dates; reverse lookup and per-date queries via authenticated API. No DNS/IP/RDAP data.	Only true source for wordlist-DGA labels (Matsnu, Suppobox, Gozi; others such as Nymaim2 used in recent work). Infrastructure must be added by your own enrichment.
CHMOR DGA dataset (GitHub)	Per your log: 25 families, Netlab DGA plus Alexa benign, domain strings only.	Lexical baseline and family analysis only. Cannot be joined to your graph (0 overlap).
OpenINTEL	Historical active-DNS measurements (per your log: A/AAAA/NS/ASN etc.).	Historical infrastructure for benign and registered domains; DGA coverage was ~2% in your test.
Tranco list	Research-oriented popularity ranking used as benign source in DGA papers.	Larger, more reproducible benign pool than a single Umbrella dump.

Two structural facts that shape every design choice

- **DGA domains mostly have no infrastructure.** A DGA emits huge numbers of candidates; the DGArchive measurement study found registration collisions to be rare outside wordlist and very short domains. So an infrastructure graph can only describe the small registered or sinkholed subset. This is my inference from those published figures, and it agrees with your ~2% coverage result. Report it as a limitation, not a bug.
- **You cannot recover past DNS by scanning today.** Active enrichment of a DGArchive domain gives its *current* state, not its state when generated. Temporal claims therefore need passive DNS or OpenINTEL, or must be limited to what the collection timestamp supports. Sinkholed domains will resolve to sinkhole IPs, which can become a new label shortcut.

5. Final scope that can actually happen

Recommended primary deliverable (Option A, no external approvals needed)

- **Title/claim:** heterogeneous infrastructure-graph detection of malware domains (Domain, IP, ASN, nameserver, registrar, *TLS certificate*) on the Zenodo corpus. Drop 'wordlist-DGA' and 'DGArchive' wording.
- **Data:** malicious = malware.json domains; benign = a much larger Umbrella/CESNET sample (hundreds of thousands are available), drawn across the same time range.
- **Baselines (same split):** char n-gram lexical, XGBoost on tabular features, graph model, graph + lexical.
- **Splits:** time-aware where both classes exist, plus a connected-component (group) split, plus a random split reported only as the optimistic bound.
- **Model:** keep heterogeneous GraphSAGE as the baseline; add an attention variant using PyTorch Geometric's HGTCov or HANConv, described as SHetGCN-inspired. A faithful SHetGCN needs client query logs (client nodes) you do not have.
- **Metrics:** ROC-AUC, PR-AUC, and TPR at fixed FPR (1% and 0.1%) with bootstrap confidence intervals. At 0.1% FPR you need thousands of benign test negatives (2,250 negatives allow only 2 false positives), so use the larger benign pool.
- **Robustness (scoped):** a defined structural attack (attacker registers domains that share nameserver/registrar/certificate nodes with benign infrastructure) evaluated as clean vs attacked. Present GNNGuard as related work or a limited adaptation; it was published for standard GNNs, and a heterogeneous port is your own research.

- **Latency:** measure ms per query on your CPU with a written protocol (feature lookup, subgraph build, forward pass, end to end).

Optional extension (Option B, only if credentials arrive)

- Email DGArchive for access from an institutional (ISRO/university) address, stating research use. Timeline is outside your control, so do not build the schedule on it.
- With access: pull wordlist families (Matsnu, Suppobox, Gozi and any others available), enrich with DNS/RDAP/TLS yourself, and treat coverage (share that resolves) as a headline number.
- Compare against the lexical wordlist-DGA literature; note that published wordlist-DGA work reports lexical detectors struggling on Matsnu, so a graph signal is a genuine research question.

Cut or reframe as future work

Proposal item	Decision	Reason
Streaming, per-event updates, TTL 60-300 s	Future work	Dataset is scan snapshots; no event-level timestamps. Can only be simulated, and must be labelled a simulation.
Continual learning	Future work (or a simple retrain-per-window comparison)	Needs a defined update rule and drift data. Rolling retraining is an honest substitute.
Full GNNGuard defence	Limited adaptation or future work	No maintained heterogeneous implementation; attack threat model comes first.
BGP/routing modality	Use ASN only	Zenodo provides ASN/GeoIP, not BGP paths.
Real-time claims	Report measured CPU latency only	No production traffic available.

6. Limitations to state in the paper

- **Label provenance:** malware domains come from threat-intelligence feeds, not DGA reimplementations; families are heterogeneous or 'unknown'.
- **Benign bias:** Umbrella/CESNET domains are popular or observed live, which differs from the non-existent-domain traffic DGA detectors face in practice.
- **Survivorship:** only domains with observable infrastructure enter the graph; unregistered DGA output is invisible to it.
- **Single vantage point and date:** one measurement site (Brno) and a 2024 collection; infrastructure ecosystems differ by region and change over time.
- **Class balance:** 50/50 evaluation overstates precision; real prevalence is far lower, so report precision at realistic prevalence or use PR-AUC with that caveat.
- **Transductive graph and near-disjoint classes:** reported infrastructure sharing between classes is about 0.02% (IP), so the graph is nearly two components; group-split results are the honest generalisation estimate.
- **Small graph:** about 30k domains and 70k nodes, single seed families of experiments; wide confidence intervals are expected.

7. Ordered plan with acceptance checks

Step	Task	Done when
1	Correct README and problem scope (malware domains, Zenodo provenance); delete synthetic results from any results table	No mention of DGArchive as a data source unless access is obtained
2	Per-snapshot class counts; resolve the note-14 contradiction	Table committed to results/
3	Resample benign across the same time range; rebuild snapshots	Every evaluated window has both classes
4	Lexical + XGBoost + graph on identical splits; single-feature shortcut baselines	One comparison table, 5 seeds, mean +/- std
5	Recompute fanin/standardisation from training data only	No feature uses test or future rows

Step	Task	Done when
6	Add TLS certificate node type from Zenodo certificate fields	Ablation shows its contribution
7	Attention variant (HGT/HAN) vs GraphSAGE	Same splits, same tuning budget
8	FPR-anchored metrics, bootstrap CIs, latency protocol, structural attack (clean vs attacked)	Numbers with intervals in results/tables
9	Send DGArchive access request in parallel (optional)	Treated as bonus, not dependency

8. Sources consulted

- Zenodo dataset record: <https://zenodo.org/records/14332167> and Data in Brief article, DOI 10.1016/j.dib.2025.112062 (PMC12495040)
- DGArchive access page: <https://dgarchive.caad.fkie.fraunhofer.de/>
- Plohmann et al., A Comprehensive Measurement Study of Domain Generating Malware, USENIX Security 2016
- Sun et al., DeepDom (SHetGCN), Computers & Security 2020: <https://www.sciencedirect.com/science/article/abs/pii/S0167404820303308>
- Zhang & Zitnik, GNNGuard, NeurIPS 2020 (cited from prior knowledge, not re-fetched)
- Hwangjaa/dga-wordlist-detection (GitHub) and arXiv 2404.06236 for DGArchive usage in recent work
- Items marked 'per your log' (CHMOR, OpenINTEL, Netlab, MegaWeb, Splunk BOTS) were not independently re-verified.